

SMB Brute Force Detection & Network Telemetry Analysis in a Corporate AD Environment

Author: John Brown

Role: SOC / Blue Team Analyst

Table of Contents

1. Executive Summary
2. Lab Environment and Topology
3. Objectives
4. Tools and Data Sources
5. Attack Execution (Kali)
6. Network Detection (Security Onion)
7. Packet-Level Evidence (Wireshark)
8. SIEM Detection and Dashboards (Splunk)
9. Findings and Recommendations

1. Executive Summary

This lab demonstrates end-to-end detection of a Server Message Block (SMB) brute force attack against a Windows Server domain controller in a simulated corporate Active Directory environment. Using Kali Linux as the attack platform, I launched an SMB credential stuffing/brute force attack against TCP port 445. The activity was monitored at multiple layers:

- Network telemetry using Security Onion and Zeek NTLM logs
- Deep packet inspection in Wireshark
- Windows event logs ingested into Splunk for correlation and dashboarding

The goal of this project is to showcase practical SOC/Blue Team skills: understanding how an SMB brute force looks on the wire, how it is reflected in authentication logs, and how to build detections and visualizations that a security operations center could use to quickly identify and investigate this behavior.

2. Lab Environment and Topology

The lab is built with multiple virtual machines running in VMware Workstation. A pfSense firewall routes traffic between VLANs, a Windows Server 2019 machine acts as the domain controller and SMB server (SRV.test.local), and a Windows 11 client is joined to the domain. Kali Linux is used as the attack machine, with Security Onion deployed as a network monitoring sensor and Splunk running on an Ubuntu server to ingest Windows event logs.

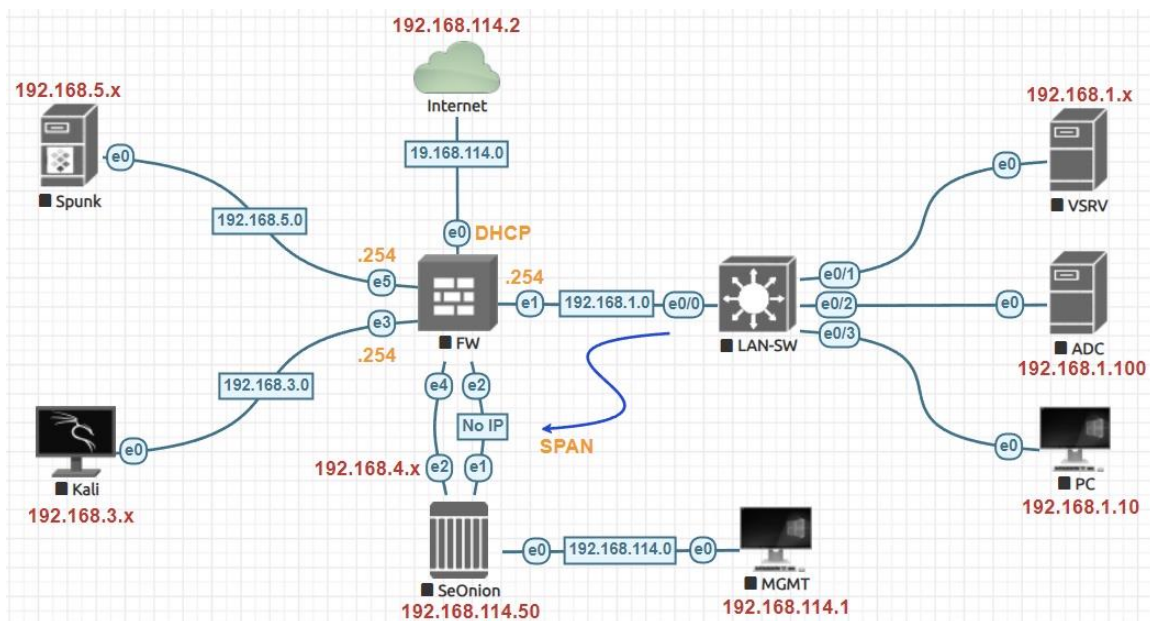


Figure 1: High-level lab topology showing pfSense, Kali attack machine, Windows 11 client, Windows Server 2019 domain controller, Security Onion sensor, and Splunk server connected in a routed virtual network.

3. Objectives

The specific objectives of this lab were:

1. Launch an SMB brute force attack from Kali against the Windows Server SMB service (TCP/445).
2. Capture and analyze the network traffic generated by the attack using Wireshark and Security Onion.
3. Confirm that the attack is reflected in Windows security logs as repeated failed logons and successful logons.
4. Build Splunk searches and dashboards to detect and visualize the brute force behavior.
5. Document the full detection workflow for use in a cybersecurity portfolio.

4. Tools and Data Sources

The following tools and data sources were used in the lab:

- Kali Linux: Metasploit Framework for SMB brute forcing and Nmap for SMB enumeration.
- Windows Server 2019: Domain controller and SMB file server (SRV.test.local).
- Security Onion: Network security monitoring platform using Zeek, Suricata.
- Wireshark: Packet capture and protocol analysis on the Security Onion sensor interface.
- Splunk: Ingestion and analysis of Windows Security event logs (notably Event IDs 4624 and 4625).

5. Attack Execution (Kali)

On the Kali attack machine, I used the Metasploit auxiliary module 'scanner/smb/smb_login' to perform an SMB login brute force against the target server at 192.168.1.100. The module was configured with a user list and password list stored on disk and then executed to attempt logins over TCP port 445.

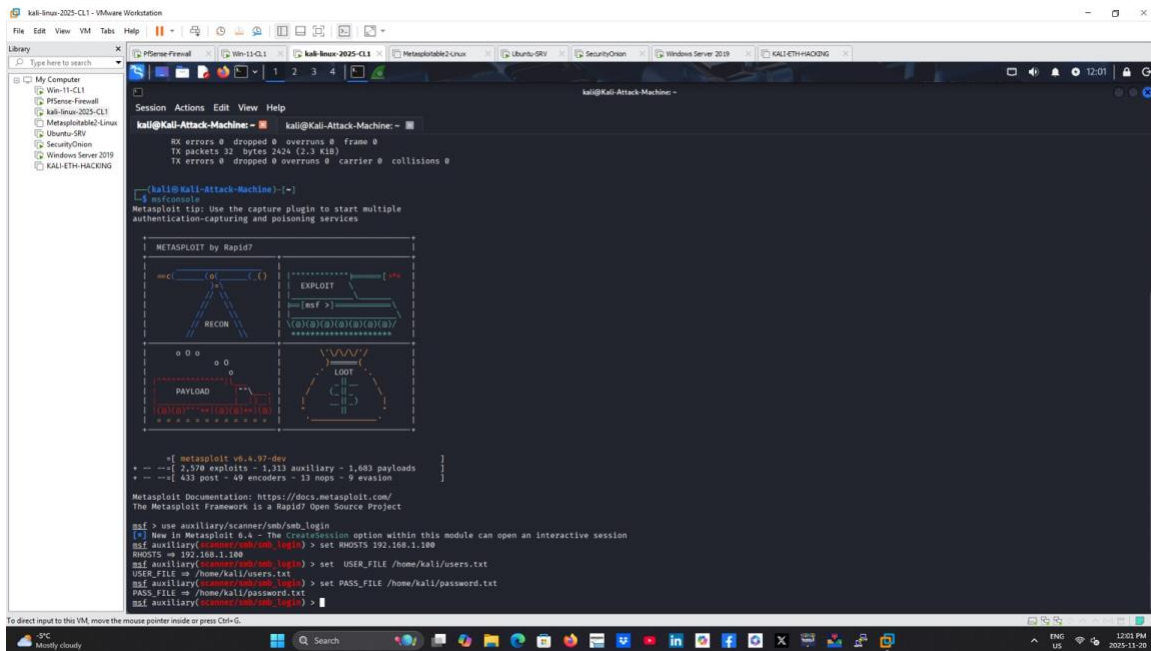


Figure 2: Launching Metasploit on Kali and selecting the auxiliary/scanner/smb/smb_login module. The RHOSTS option is set to 192.168.1.100 (the SMB server), and the USER_FILE and PASS_FILE options are pointed to local wordlists containing test usernames and passwords.

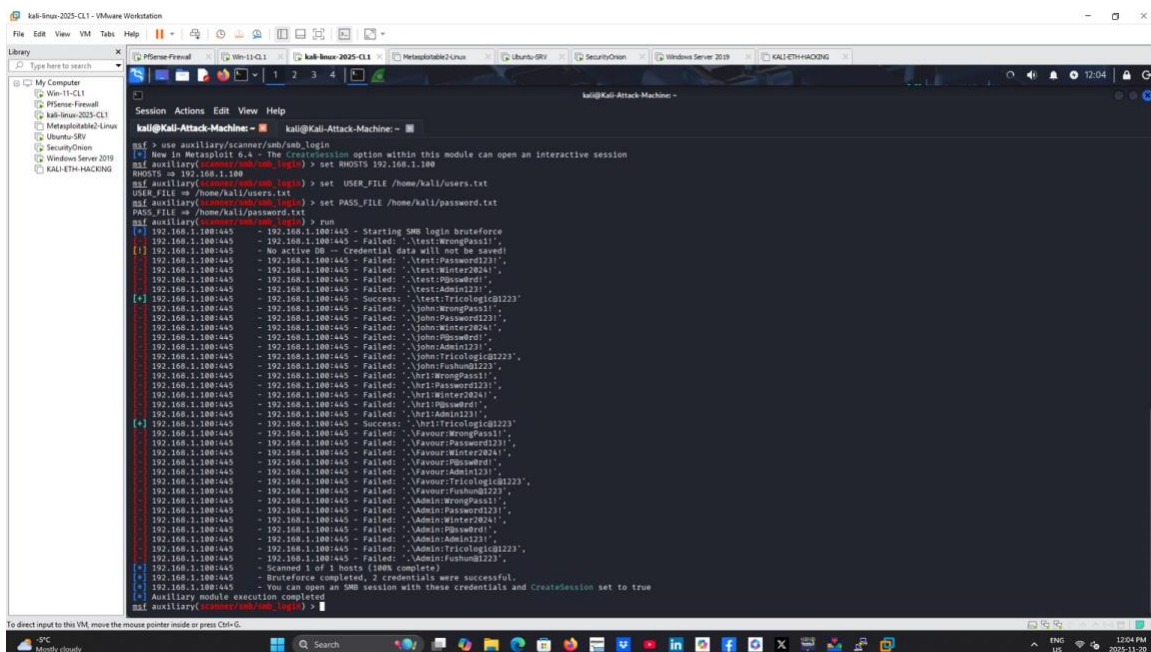


Figure 3: Metasploit smb_login brute force in progress. Each line shows an attempted SMB login from Kali (192.168.3.1) to the server 192.168.1.100 on port 445 with a candidate username and password. The output clearly indicates Failed attempts and highlights two successful credential pairs, confirming that the brute force attack worked.

After confirming that the SMB service was reachable, I used several Nmap NSE scripts to gather more context about the SMB configuration on the server, including supported dialects, security mode, and shares.

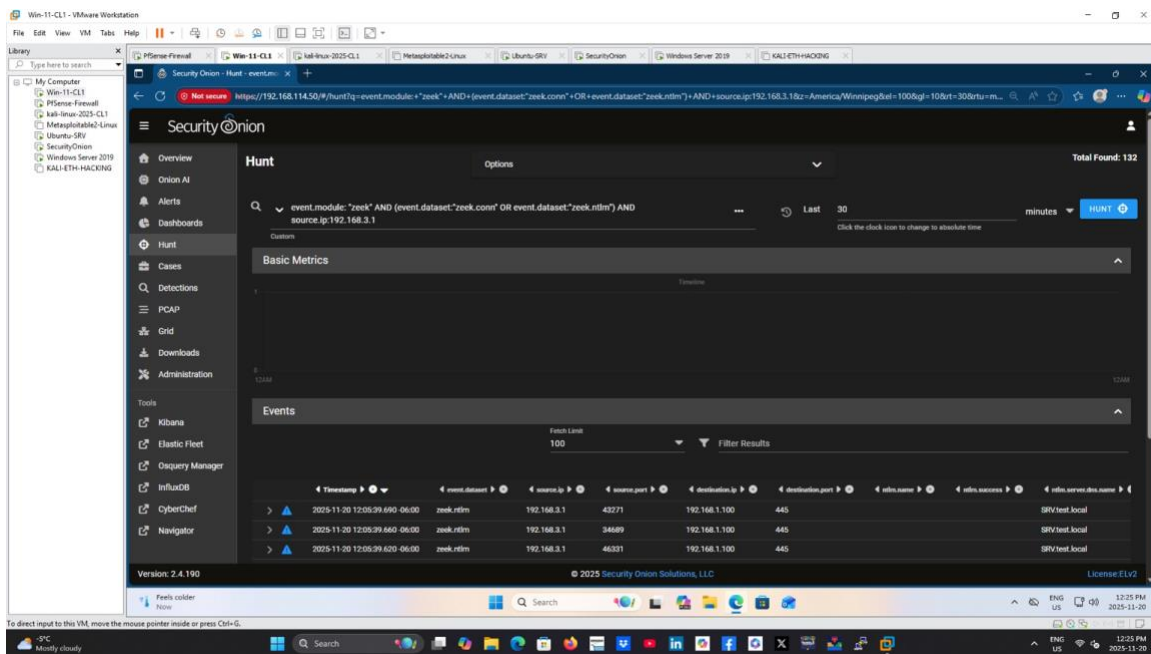


Figure 4: Nmap scan using the smb-vuln-ms17-010 script against TCP port 445 on 192.168.1.100. This checks whether the server is vulnerable to the EternalBlue exploit (MS17-010), an important pre-check before launching certain post-exploitation techniques in a real engagement.

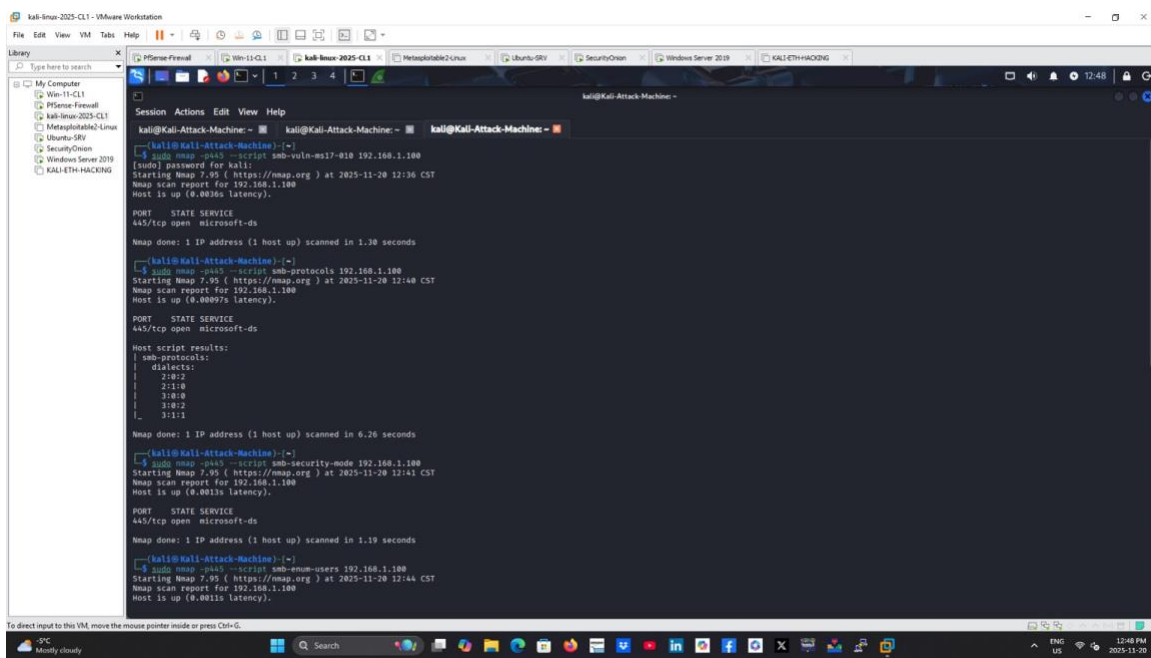
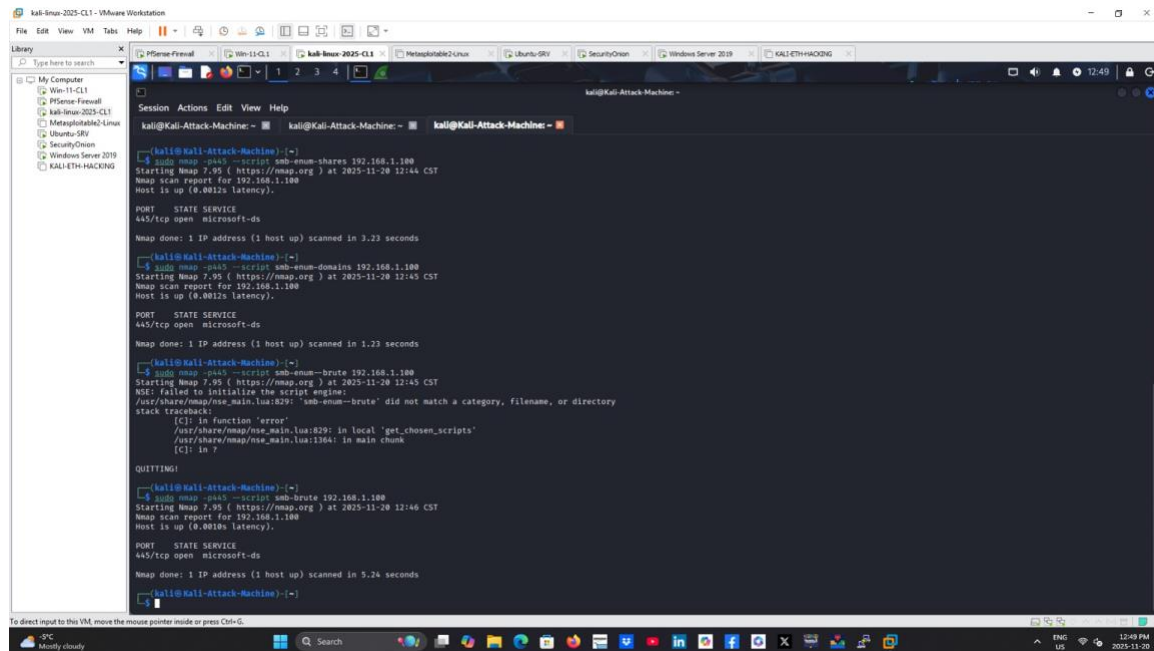


Figure 5: Nmap smb-protocols and smb-security-mode scripts being run against 192.168.1.100. The results reveal which SMB protocol versions are supported (e.g., 2.0.2, 2.1, 3.x) and show that message signing is enabled, providing insight into the hardening level of the SMB configuration.



```
kali@kali-2025-CL1: VMWare Workstation
File Edit View VM Tabs Help
Library
Type here to search
My Computer
Kali-2025-CL1
Kali-2025-CL1
Metasploit642-Linux
Ubuntu-SRV
SecurityOnion
Windows Server 2019
KALI-ETH-HACKING

kali@Kali-Attack-Machine: ~
kali@Kali-Attack-Machine: ~
kali@Kali-Attack-Machine: ~

kali@Kali-Attack-Machine:~$ sudo nmap -p445 --script smb-enum-shares 192.168.1.100
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-20 12:44 CST
Nmap scan report for 192.168.1.100
Host is up (0.0012s latency).

PORT      STATE SERVICE
445/tcp    open  microsoft-ds

Nmap done: 1 IP address (1 host up) scanned in 3.23 seconds

kali@Kali-Attack-Machine:~$ sudo nmap -p445 --script smb-enum-domains 192.168.1.100
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-20 12:45 CST
Nmap scan report for 192.168.1.100
Host is up (0.0012s latency).

PORT      STATE SERVICE
445/tcp    open  microsoft-ds

Nmap done: 1 IP address (1 host up) scanned in 1.23 seconds

kali@Kali-Attack-Machine:~$ sudo nmap -p445 --script smb-enum-brute 192.168.1.100
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-20 12:45 CST
NSE: failed to initialize the script engine!
/usr/share/nmap/nse_main.lua:829: 'smb-enum-brute' did not match a category, filename, or directory
stack traceback:
  [C]: in function 'error'
  /usr/share/nmap/nse_main.lua:829: in local 'get_chosen_script'
  /usr/share/nmap/nse_main.lua:1364: in main chunk
  [C]: in ?

QUITTING!

kali@Kali-Attack-Machine:~$ sudo nmap -p445 --script smb-brute 192.168.1.100
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-20 12:46 CST
Nmap scan report for 192.168.1.100
Host is up (0.0010s latency).

PORT      STATE SERVICE
445/tcp    open  microsoft-ds

Nmap done: 1 IP address (1 host up) scanned in 5.24 seconds

kali@Kali-Attack-Machine:~$
```

Figure 6: Additional Nmap SMB enumeration scripts, including smb-enum-shares and smb-enum-domains, are executed to identify accessible shares and domain information. An attempt to run smb-enum-brute shows an NSE script error, demonstrating troubleshooting skills and awareness of script naming/category issues.

6. Network Detection (Security Onion)

Security Onion was used to monitor the network traffic generated by the SMB brute force attack. Using the Hunt interface, I focused on Zeek connection and NTLM logs originating from the Kali attack machine's IP (192.168.3.1) and targeting the SMB server (192.168.1.100) on TCP port 445.

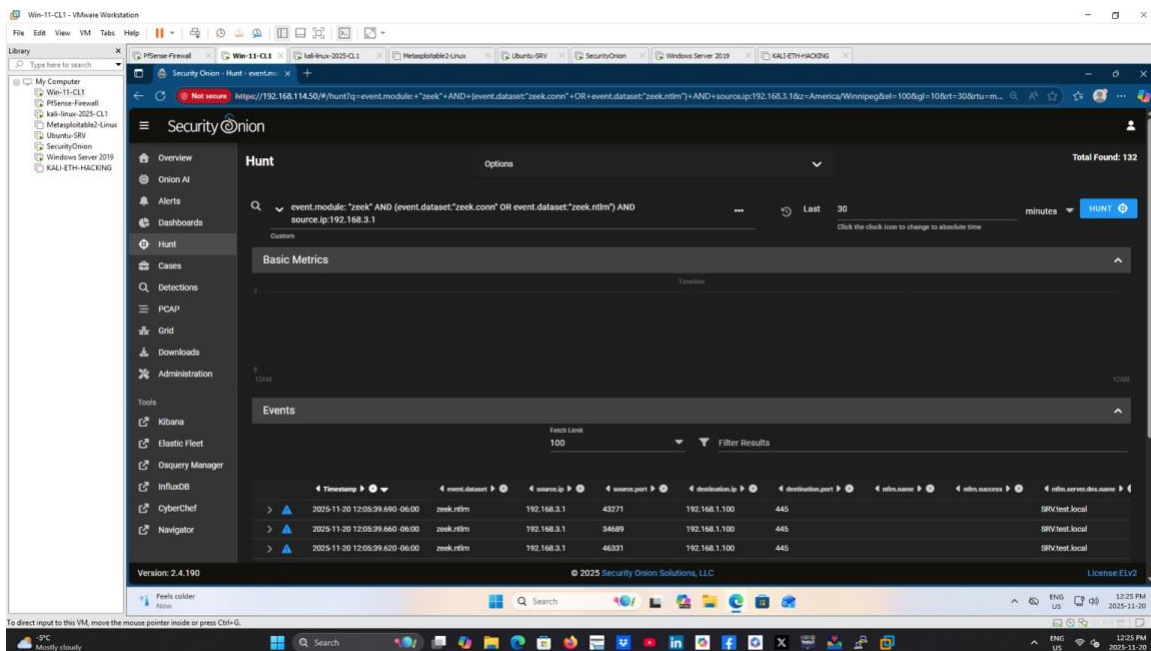


Figure 7: Security Onion Hunt query filtering for Zeek events where event.module is 'zeek' and dataset is either zeek.conn or zeek.ntlm, with source.ip set to 192.168.3.1. This search isolates traffic generated by the Kali attack machine during the SMB brute force activity.

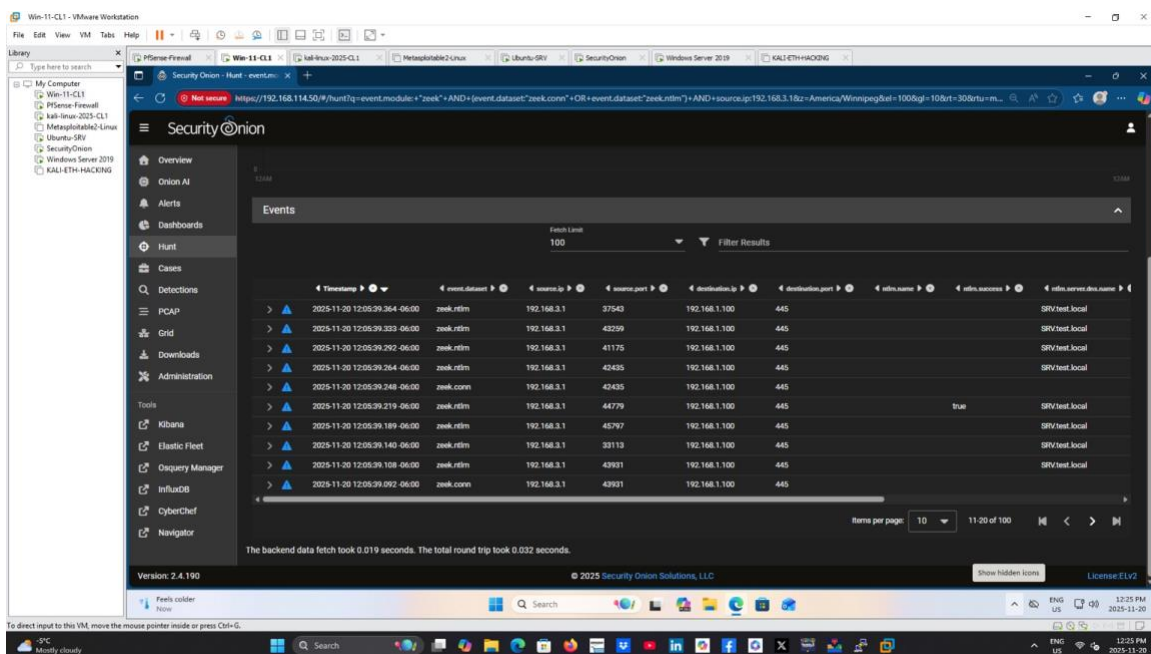


Figure 8: Hunt results showing multiple zeek.ntlm events from 192.168.3.1 to 192.168.1.100 on destination port 445. Each event represents an NTLM authentication attempt over SMB, confirming that the brute force is visible as a series of NTLM logon attempts at the network layer.

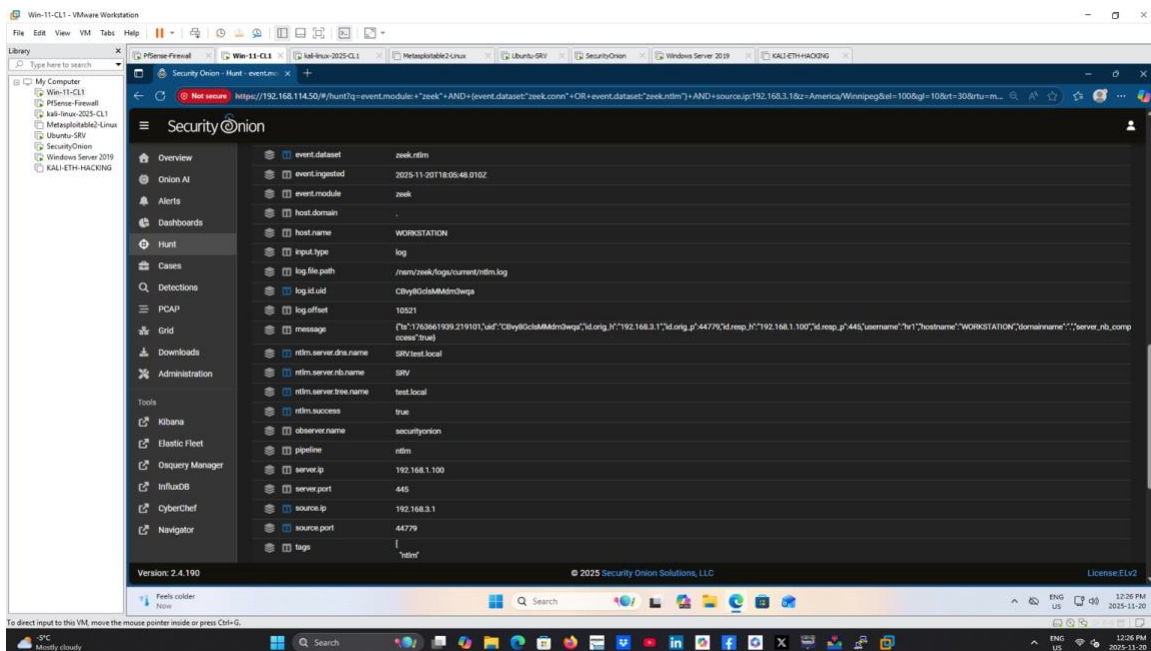


Figure 9: Detailed view of a single zeek.ntlm event. Important fields include ntlm.server.dns.name (SRV.test.local), ntlm.success, source_ip (192.168.3.1), and server_ip (192.168.1.100). This record shows a successful NTLM authentication, mapping directly to one of the credentials that Metasploit discovered.

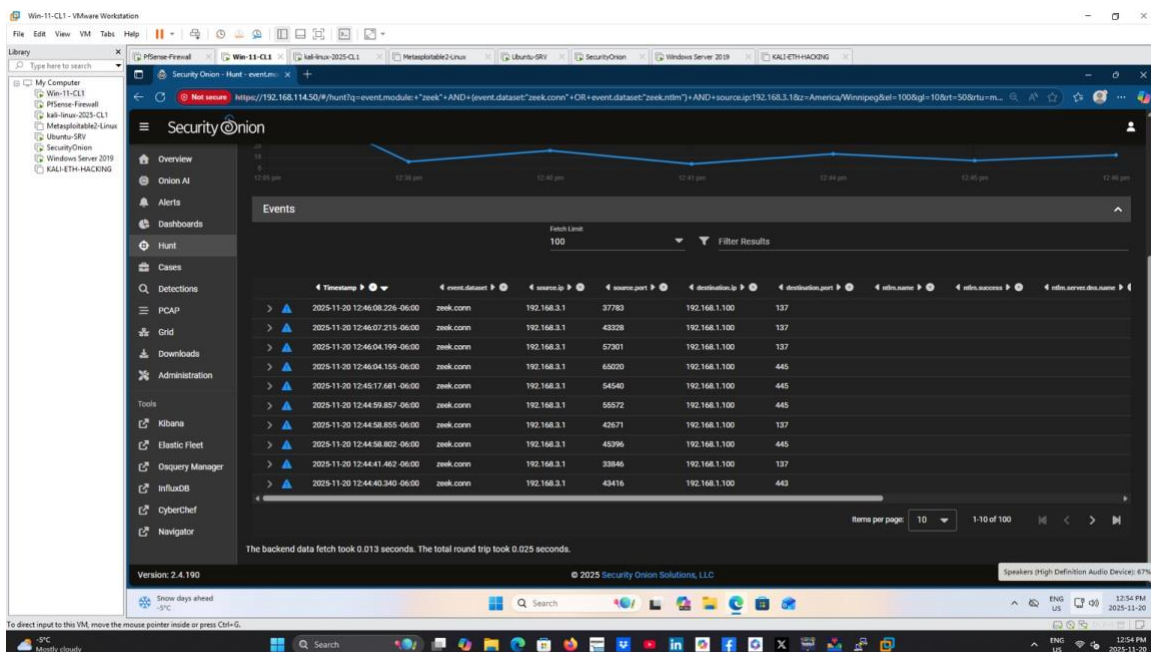


Figure 10: Combined view of zeek.conn and zeek.ntlm events for the same time range. Connection-level logs show repeated TCP sessions to port 445, while NTLM logs provide higher-level authentication context. Together, these logs give a complete picture of the brute force behavior from a network monitoring perspective.

7. Packet-Level Evidence (Wireshark)

To understand the SMB brute force at the packet level, I captured traffic on the Security Onion sensor interface using Wireshark. I used display filters to focus on the TCP handshake to port 445 and the SMB2/NTLMSSP authentication messages between Kali (192.168.3.1) and the server (192.168.1.100).

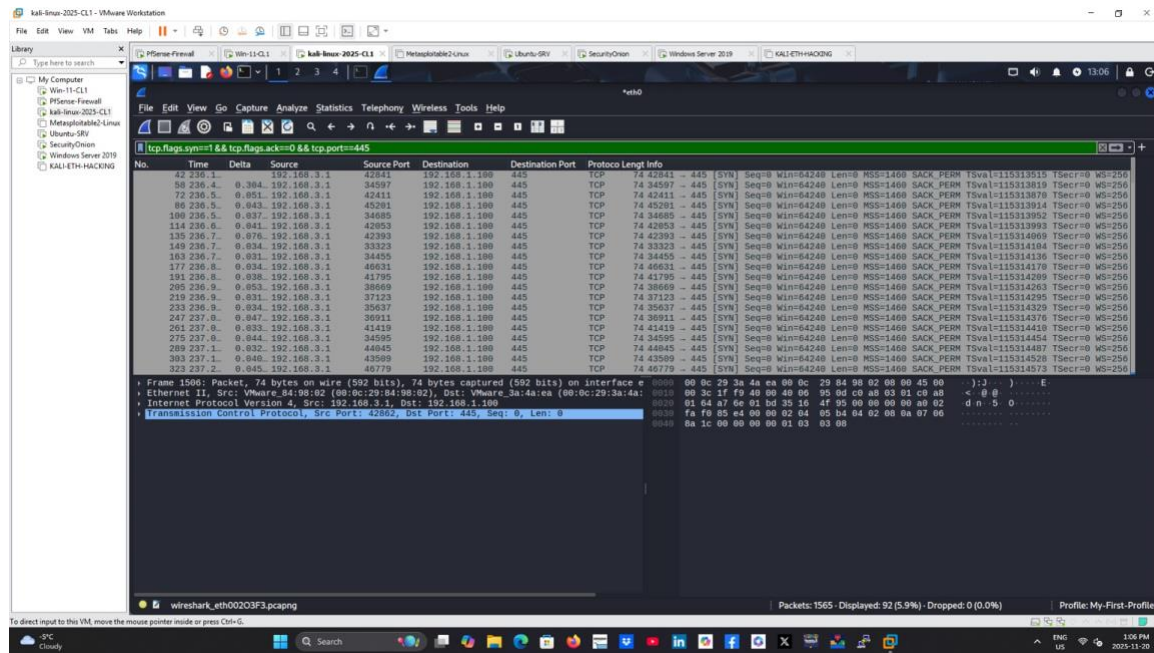


Figure 11: Wireshark filtered on 'tcp.flags.syn==1 && tcp.flags.ack==0 && tcp.port==445'. This view shows a high volume of TCP SYN packets from 192.168.3.1 to 192.168.1.100:445, representing repeated connection attempts generated by the Metasploit smb_login module during the brute force attack.

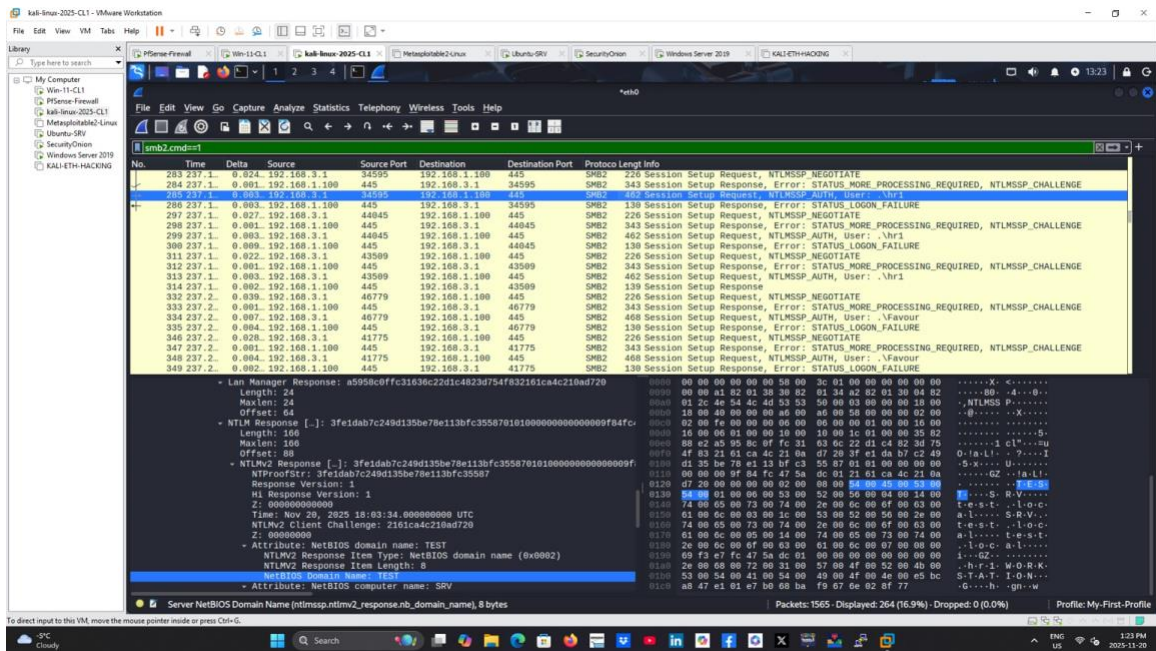


Figure 12: Wireshark display focusing on SMB2 Session Setup requests and responses that encapsulate NTLM authentication. The Info column shows STATUS_MORE_PROCESSING_REQUIRED and NTLMSSP_CHALLENGE messages, which are part of the NTLM challenge-response handshake.

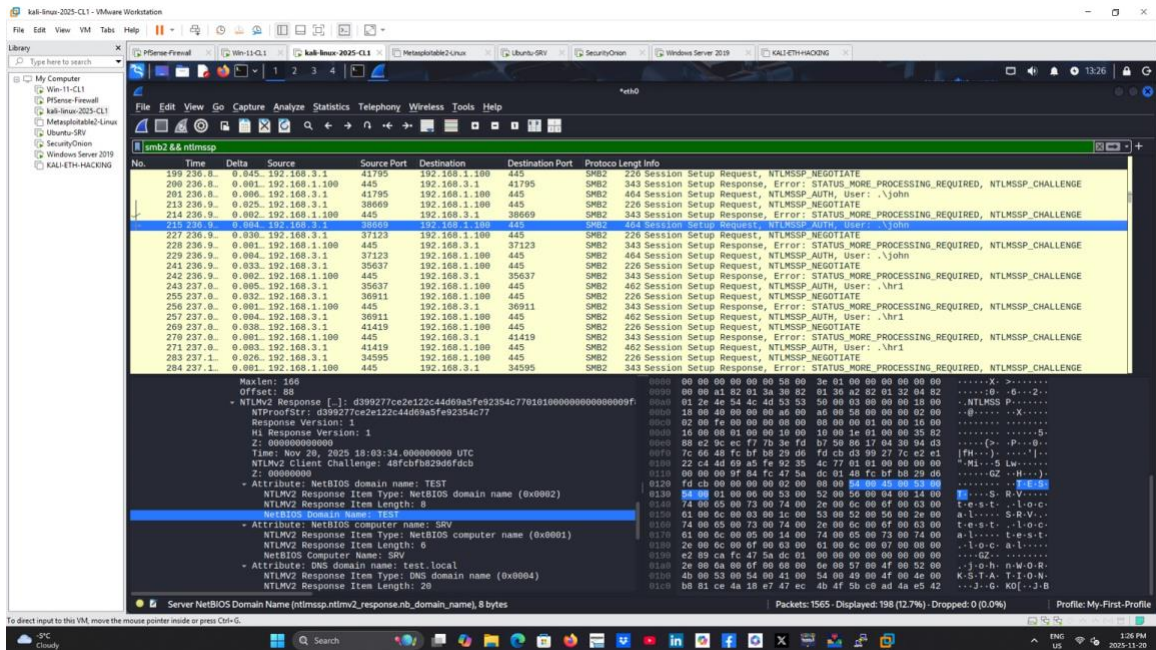


Figure 13: Drilling down into an SMB2 Session Setup Response containing an NTLM authentication response. The decoded fields reveal the NTLMv2 response, NetBIOS domain name (TEST), computer name (SRV), and other authentication metadata. This ties the network packets directly to the Active Directory domain and host involved.

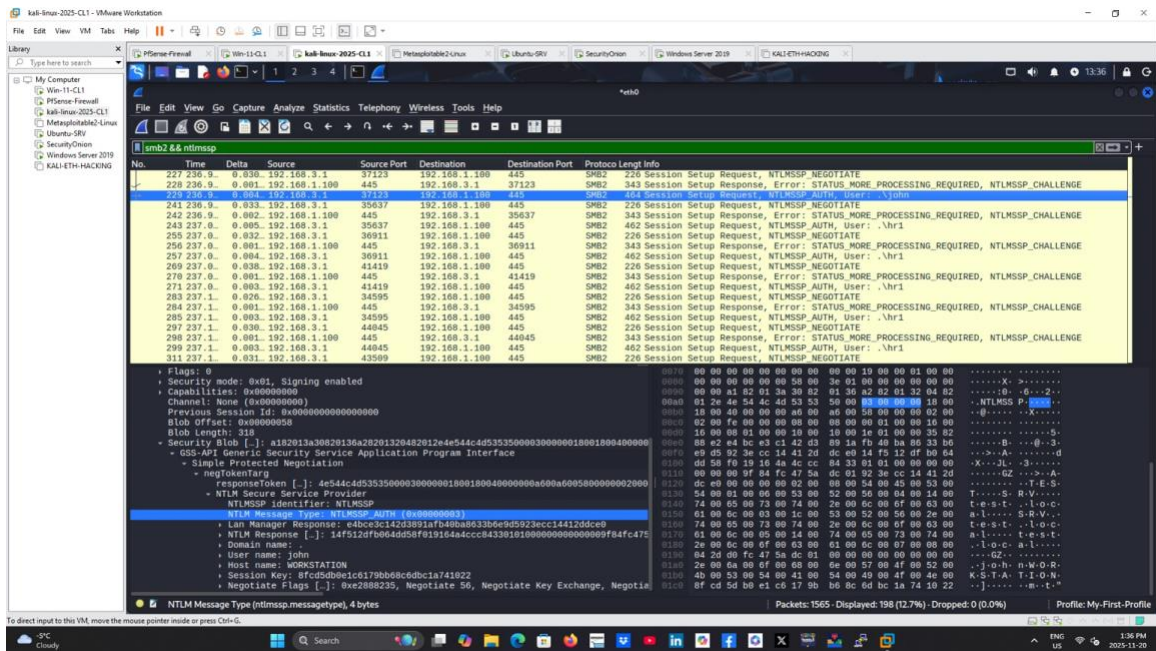


Figure 14: Another NTLMSSP_AUTH message dissected in Wireshark. The security blob includes the domain name, username, and NTLM response hash. Even though the actual password is not visible, the structure clearly shows repeated authentication attempts for different users, consistent with a brute force or credential stuffing attack.

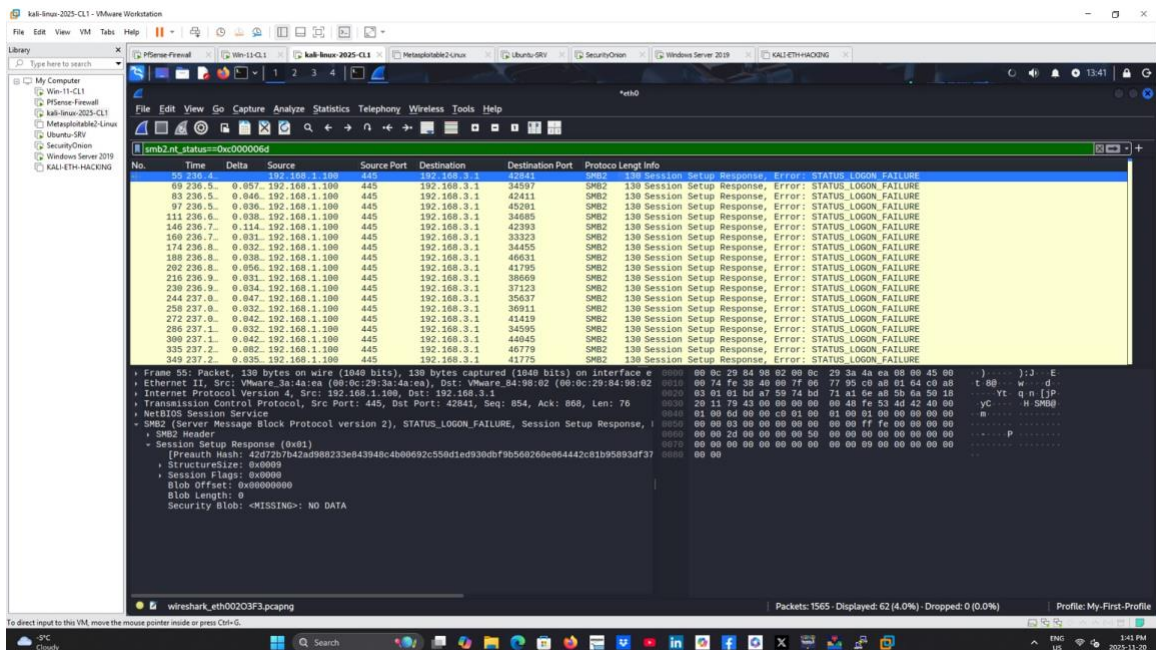


Figure 15: Wireshark view filtered on 'smb2.nt_status==0xc000006d', which corresponds to STATUS_LOGON_FAILURE. This filter highlights SMB2 packets where the server rejected the credentials. A high volume of these failures over a short time window is a strong network-level indicator of brute force activity.

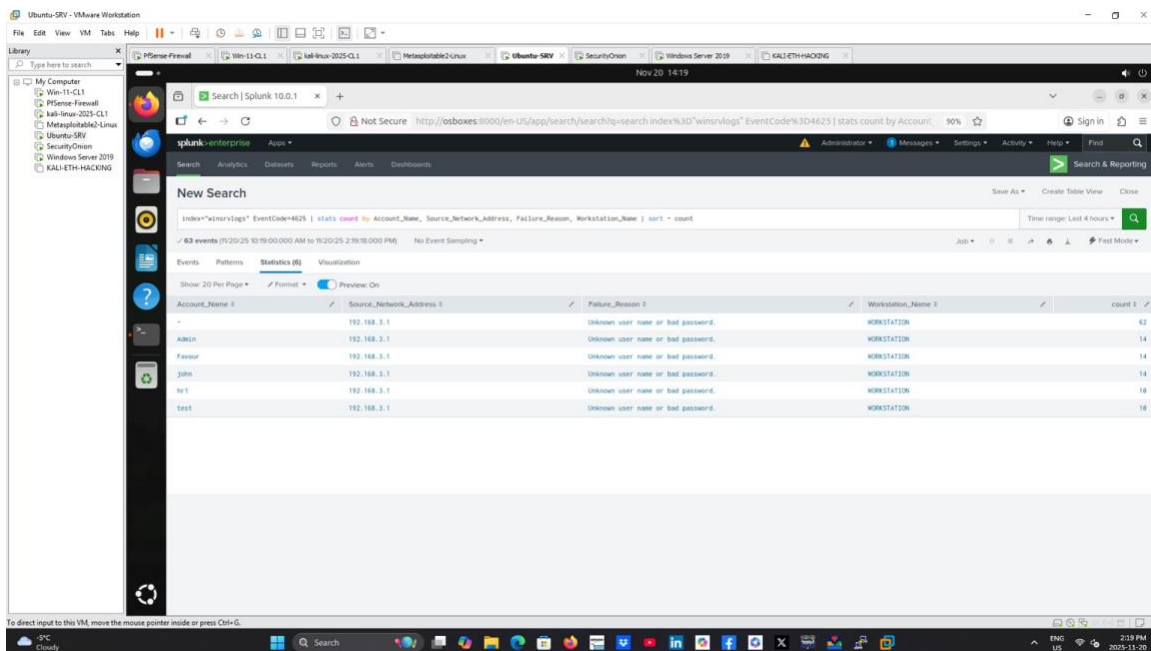


Figure 17: Splunk search aggregating EventCode 4625 by Account_Name, Source_Network_Address, Failure_Reason and Workstation_Name. This table reveals multiple accounts (Admin, Favour, john, hr1, test) all experiencing repeated 'Unknown user name or bad password' failures from the same source IP 192.168.3.1, which strongly suggests a brute force attempt.

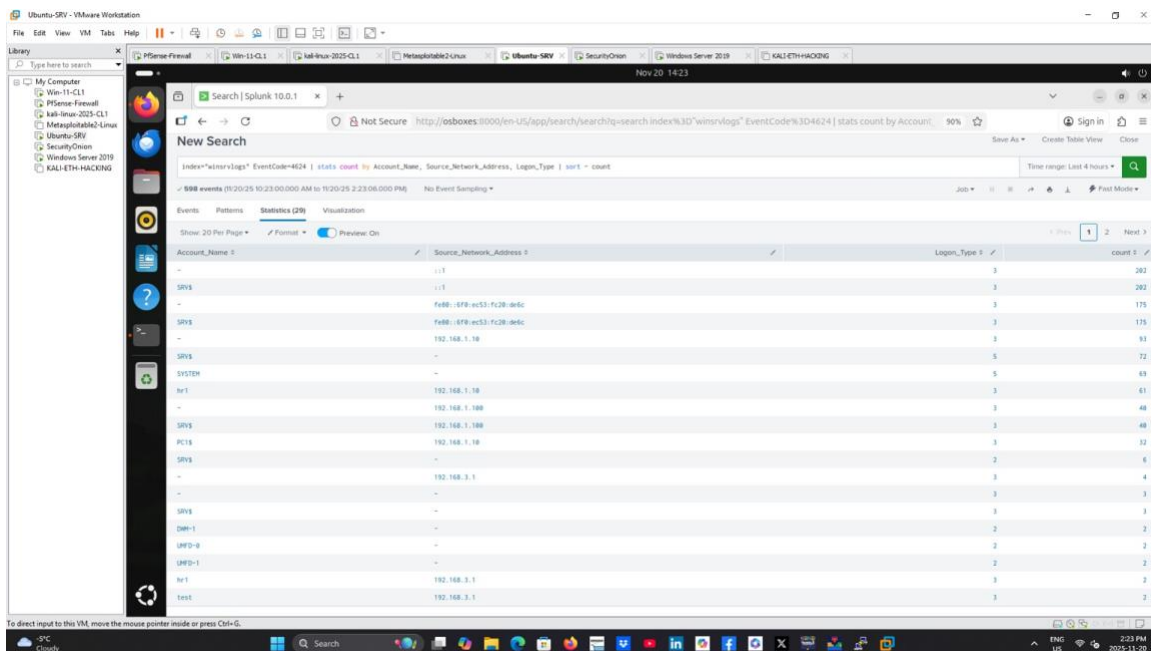


Figure 18: Statistics view grouping failed logons by Account_Name, Source_Network_Address, and Logon_Type. The high counts for accounts associated with

SRV\$ and other system accounts show normal background activity, while the pattern of failures from the attacker's IP helps differentiate malicious behavior from noise.

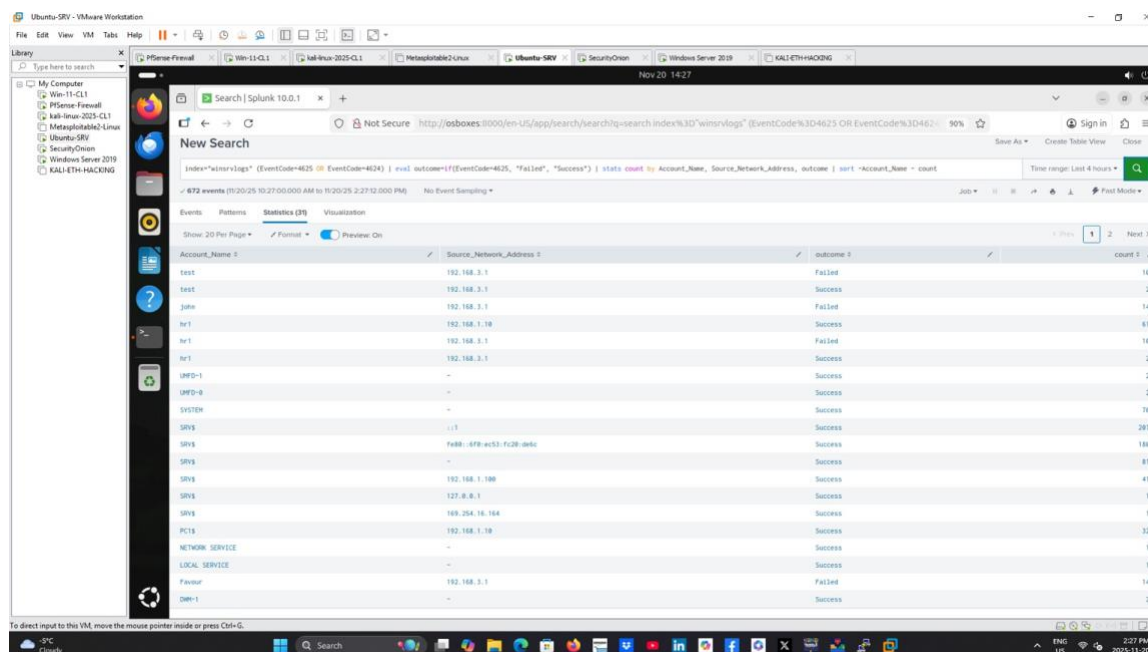


Figure 19: Search combining EventCode 4625 (failed logons) and 4624 (successful logons) and using eval to label each event as 'Failed' or 'Success'. The stats aggregation by Account_Name, Source_Network_Address, and outcome makes it easy to see which accounts had both failed and successful logons and from which IPs.

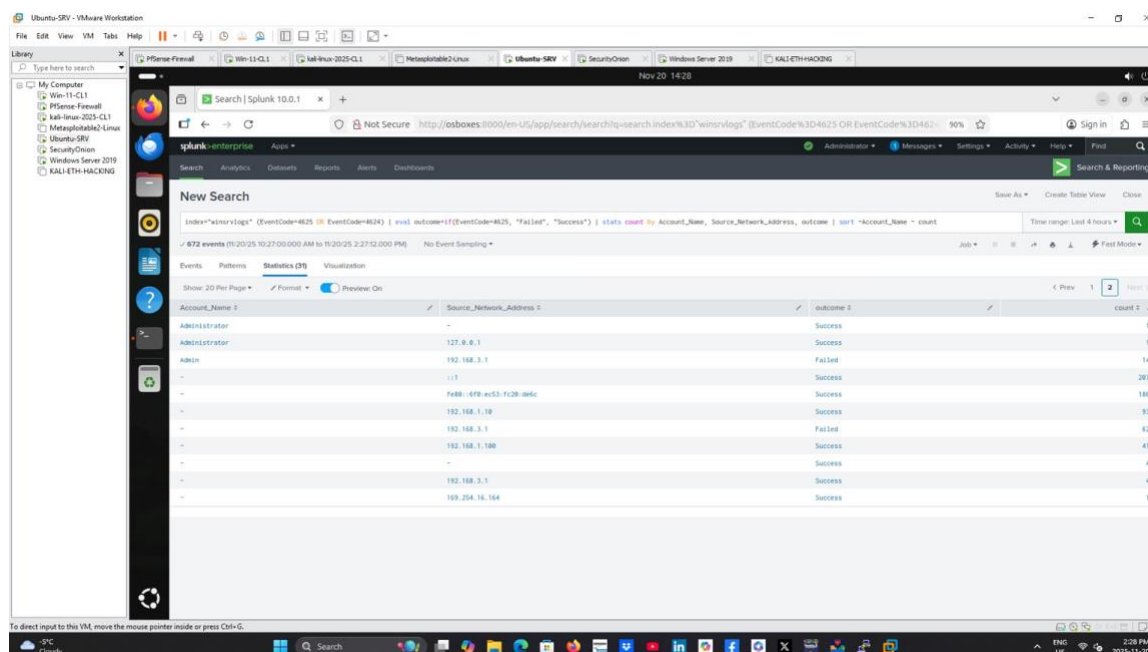


Figure 20: Continuation of the same stats view, showing Administrator, Admin, and various system accounts. The distribution of Success and Failed outcomes helps analysts quickly

identify anomalies, such as external IPs generating many failures or unusual accounts being targeted.

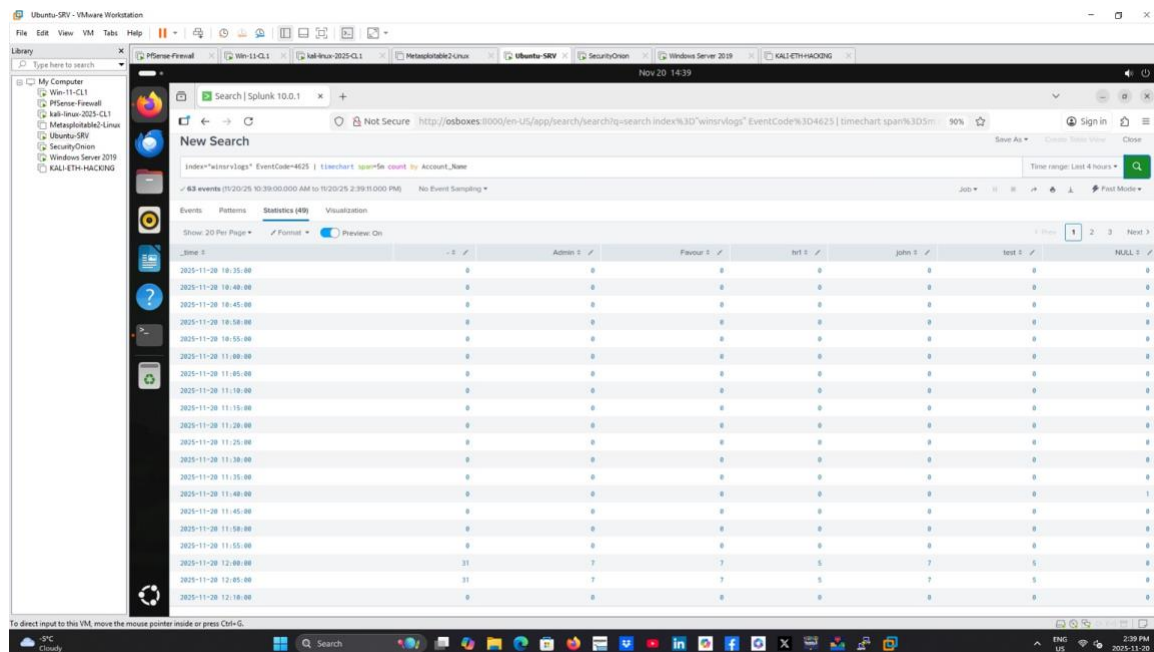


Figure 21: Splunk timechart of failed logons (EventCode 4625) split by Account_Name over five-minute buckets. A visible spike in failed logons for accounts targeted by Metasploit (Admin, Favour, hr1, john, test) lines up exactly with the period when the SMB brute force attack was launched from Kali.

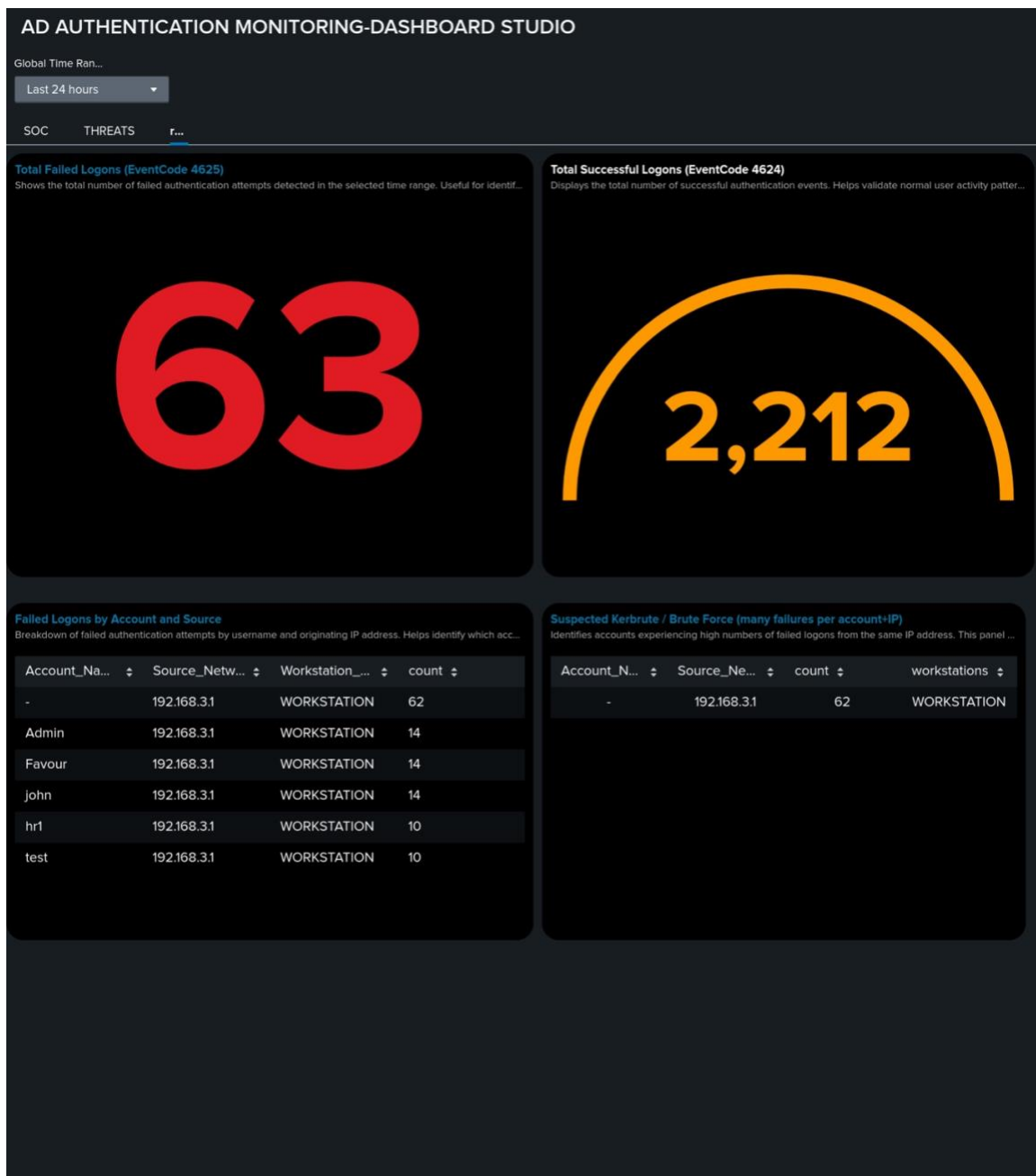


Figure 22: Custom Splunk Dashboard Studio view titled 'AD Authentication Monitoring'. The panels show the total number of failed logons (63), total successful logons (2,212), a breakdown of failed logons by account and source IP, and a dedicated panel for suspected Kerbrute/brute force activity. The dashboard clearly isolates 192.168.3.1 as a suspicious source with 62 failures, making it easy for SOC analysts to triage the incident.

9. Findings and Recommendations

This lab confirms that an SMB brute force attack:

- Generates a high volume of TCP connections to port 445 from the attacker host.

- Produces numerous NTLM authentication attempts visible in Zeek and Wireshark.
- Results in repeated Windows Security Event 4625 entries for the targeted accounts.
- Can be effectively surfaced in Splunk using aggregation, timechart, and dashboard visualizations.

Key recommendations for defending against similar attacks include:

- Enforcing strong password policies and account lockout thresholds to limit brute force success.
- Monitoring for high volumes of failed SMB/NTLM logons from a single IP or against a small set of accounts.
- Creating SIEM alerts for repeated Event ID 4625 with the same Source_Network_Address and Account_Name.
- Restricting SMB exposure by segmenting networks, limiting access to TCP/445, and using firewalls to block untrusted hosts.
- Continuing to refine dashboards like the ones built in this lab so SOC analysts can quickly identify and investigate suspicious authentication patterns.